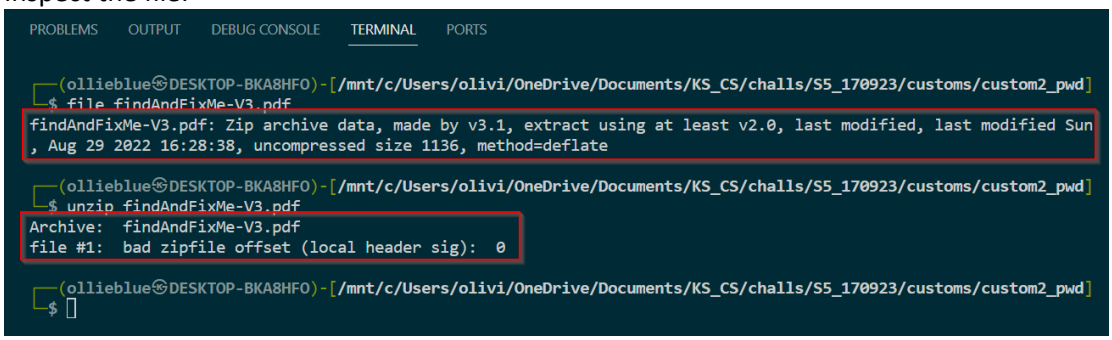
Session 5 (week of 17 September 2023)

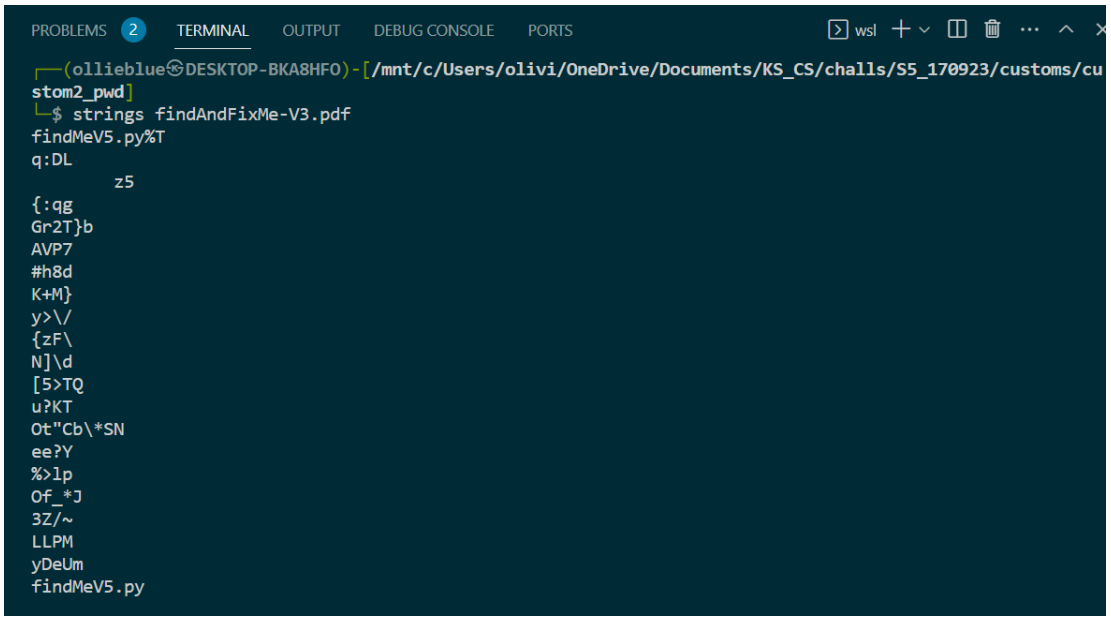
Custom 2 - (Hard): Please solve this custom challenge:
Download it from here.

Hint: Eventually, you need to run the program and guess the password!
It's a combination of Forensic and Reverse Engineering/Obfuscation.

Steps undertaken to solve the challenge

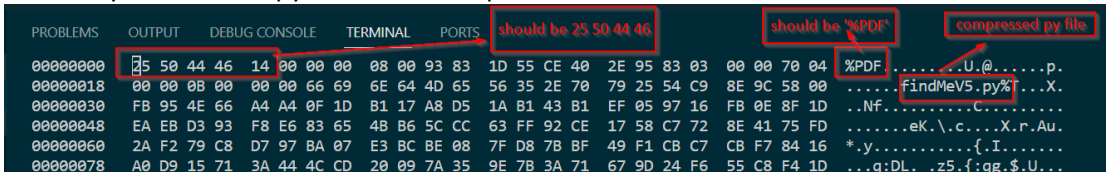
1. Inspect the file:





From this point onwards, these steps were learnt during the review and analysis session in class.

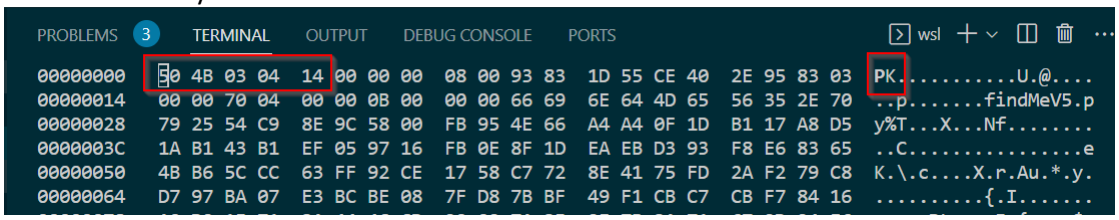
2. The results above shows that this is not a typical representation of zip file. So we need to find out what file this is and reverse it to its original --execute 'hexedit findAndFixMe-V3.pdf' and you'll see that the header is pdf (although not the correct pdf file signature), but it is also a zip file because you can see a python file is compressed within it:



3. So we need to change the file signature to the correct one as per the reference for zip file below (you can see in Wikipedia or other websites), zip file signature is '50 4B 03 04' with PK header:

`50 4B 03 04`	PK‍	0	maff msix odp ods	zip file format and formats based on it, such as EPUB, JAR, ODF, OOXML
`50 4B 05 06` (empty archive)	PK‍			
`50 4B 07 08` (spanned archive)	PK‍			

4. We can manually do this:



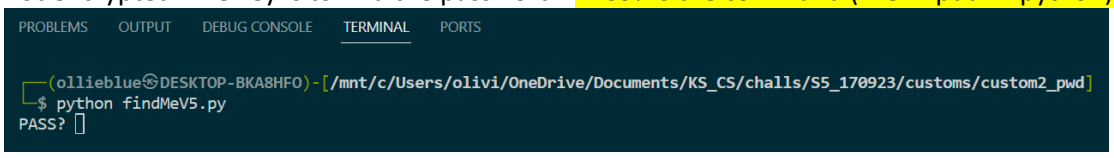
5. And inspect the file again –it tells you that it is a python script with ASCII text executable and with a very long line:



Which can be displayed with strings command:



When you execute the python file, the program asked for a password –it means it's running and not encrypted. The key is to find the password –PASS? is the command (like 'input' in python)



6. Open findMeV5.py –as expected when inspecting the file, it is an ASCII text with a very long line if you keep sliding to the right:



7. So we can use python beautifier program to make the code digestible, copy and paste it onto a new 'beautified.py' file for analysis:

```
beautified.py 1
beautified.py > ...
1   from cryptography.fernet import Fernet
2
3   muHa = "bAF0rTG5AY2PMO86AtOzvcqDxibbRyfIAJ38rzvOxZVsSp6!WBi7QvOSHSd3Lz4BtpSePA6jn9Kdcqfrodr4YjP9fdgkGOBjD!N6CLOvEky
4
5
6   bb = b"EAeeFGJDUZEeaishu4qaxswNUmKcmTDn1HjrKYN8U7Y="
7
8
9   b = b"gAAAAABjDLCIjp7gZPdLEynEO0XaCNusDgM5jjUkKQ7hoXLGIQq4t5UoQw9WmsgAup3X1BkqkwWhgsQM7qYuj3piy0xpRfQnh4F6Pa6XOkXim
10
11
12  exec(Fernet(bb).decrypt(b))
13
```

It seems encryption is done using Fernet library –so we need to learn what Fernet library is.

Try printing line 12 to see if we can learn something about the python program:

```
beautified.py 1
beautified.py > ...
1   from cryptography.fernet import Fernet
2
3   muHa = "bAF0rTG5AY2PMO86AtOzvcqDxibbRyfIAJ38rzvOxZVsSp6!WBi7QvOSHSd3Lz4BtpSePA6jn9Kdcqfrodr4YjP9fdgkGOBjD!N6CLOvEky
4
5
6   bb = b"EAeeFGJDUZEeaishu4qaxswNUmKcmTDn1HjrKYN8U7Y="
7
8
9   b = b"gAAAAABjDLCIjp7gZPdLEynEO0XaCNusDgM5jjUkKQ7hoXLGIQq4t5UoQw9WmsgAup3X1BkqkwWhgsQM7qYuj3piy0xpRfQnh4F6Pa6XOkXim
10
11
12  # exec(Fernet(bb).decrypt(b))
13
14  print(Fernet(bb).decrypt(b))
15

PROBLEMS 1  TERMINAL  OUTPUT  DEBUG CONSOLE  PORTS                    wsl

┌──(ollieblue㉿DESKTOP-BKA8HFO)-[/mnt/c/Users/olivi/OneDrive/Documents/KS_CS/challs/S5_170923/customs/custom2_pwd]
└─$ touch beautified.py

┌──(ollieblue㉿DESKTOP-BKA8HFO)-[/mnt/c/Users/olivi/OneDrive/Documents/KS_CS/challs/S5_170923/customs/custom2_pwd]
└─$ python beautified.py
b"\ndyrxjtyjxfgn = input(muHa[501]+muHa[503]+muHa[55]+muHa[57]+muHa[511]+' ')\n\nif dyrxjtyjxfgn == muHa[100]+muHa[200]+muHa[300]+muHa[40
0]+muHa[500]+muHa[250]+muHa[125]+muHa[75]+muHa[50]+muHa[25]:\n  print(muHa[401]+muHa[403]+muHa[45]+muHa[47])\nelse:\n  print(muHa[201]+mu
Ha[203]+muHa[65]+muHa[67]+muHa[97])\n\n"
```

It seems like, although encrypted by Fernet library, the program is asking for input from the users using for loops and if – elif conditional statement.

8. With a bit of guessing, we can print the encrypted for loop and see the password ‘CYBERPedii’:

```
findMeV5.py 1   beautified.py 1
beautified.py > ...
1   from cryptography.fernet import Fernet
2
3   muHa = "bAF0rTG5AY2PMO86AtOzvcqDxibbRyfIAJ38rzvOxZVsSp6!WBi7QvOSHSd3Lz4BtpSePA6jn9Kdcqfrodr4YjP9fdgkGOBjD!N6CLO
4
5   for _ in muHa:
6       print((muHa[501]+muHa[503]+muHa[55]+muHa[57]+muHa[511]+' '))
7       print(muHa[100]+muHa[200]+muHa[300]+muHa[400]+muHa[500]+muHa[250]+muHa[125]+muHa[75]+muHa[50]+muHa[25])
8       print(muHa[401]+muHa[403]+muHa[45]+muHa[47])
9       print(muHa[201]+muHa[203]+muHa[65]+muHa[67]+muHa[97])
10
11  bb = b"EAeeFGJDUZEeaishu4qaxswNUmKcmTDn1HjrKYN8U7Y="
12
13  b = b"gAAAAABjDLCIjp7gZPdLEynEO0XaCNusDgM5jjUkKQ7hoXLGIQq4t5UoQw9WmsgAup3X1BkqkwWhgsQM7qYuj3piy0xpRfQnh4F6Pa6XO
14

PROBLEMS 2  TERMINAL  OUTPUT  DEBUG CONSOLE  PORTS                    wsl

yup!
nope!
PASS?
CYBERPedii
yup!
nope!
```

9. We can test if the password is correct by running the exec command:

